SANJAY KUMAR.M| Roll No: 241901100

Exercise 9

Ex. No.: 9

Perform Web Application Vulnerability Scanning

Aim:

To conduct automated vulnerability scanning of web applications using online or free tools, interpret

findings, and understand remediation basics.

Steps:

1. Use CLI tool Nikto

2. Nikto – CLI-based web server scanner that finds dangerous files and outdated software.

3. Nikto is a popular open-source web server scanner that performs comprehensive tests against web

servers for multiple items

4. nikto -h http://https://demo.testfire.net/login.jsp

Perform Web Application Vulnerability Scanning

After Downloading the Windows(64) Installer of ZAP , run the setup

After which , access the zap application

In the manual Explore option , type the url to crawl.

We can also use an option called client spider , just right click the specified url in

the sites tab and in the attack options , click client spider

Then goto Alerts:

Step 1: Initialization

- Install and launch chosen scanner.
    - OWASP ZAP: Launch GUI, configure target domain.

Step 2: Run Scan

- Start scanning:
    - For ZAP, run active scan after spidering.

Step 3: Monitor

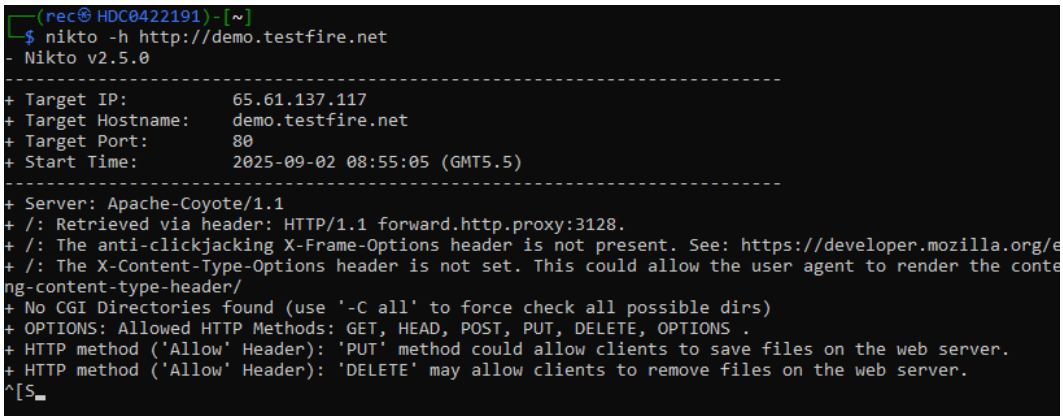
- Observe scan progression and any alerts or findings in real time.

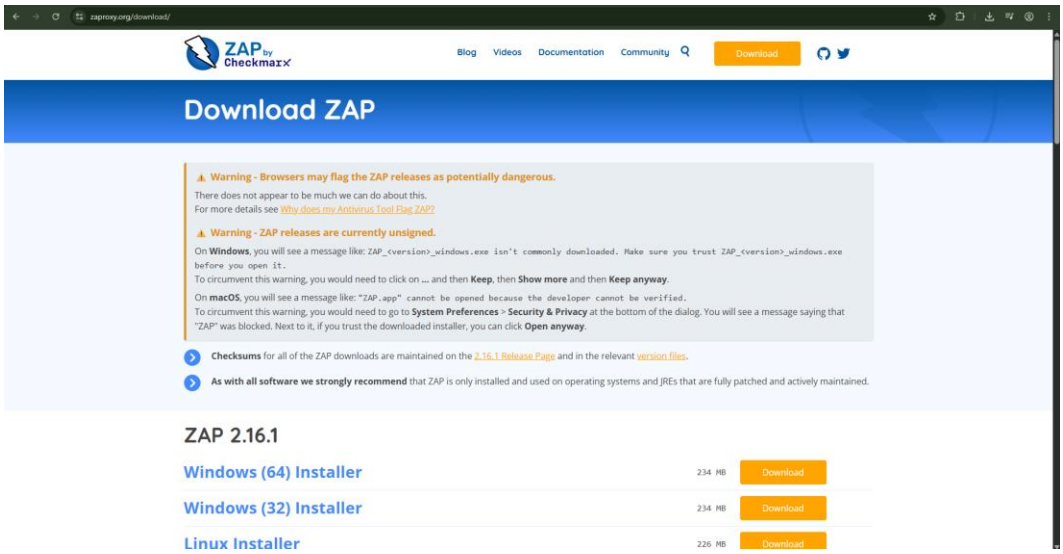
Step 4: Review Results

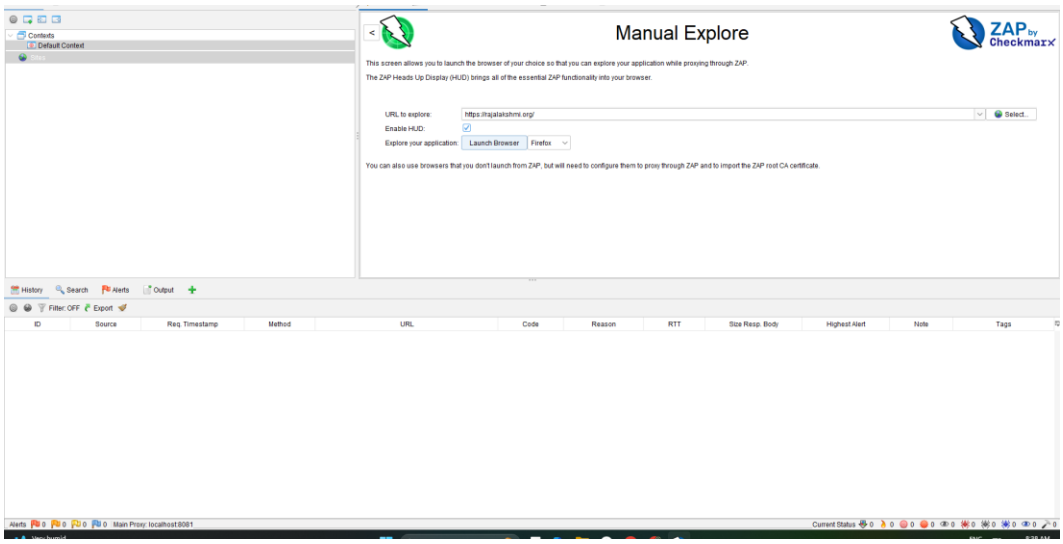
- ZAP: Review alerts pane (e.g., XSS, SQL injection, insecure cookies).

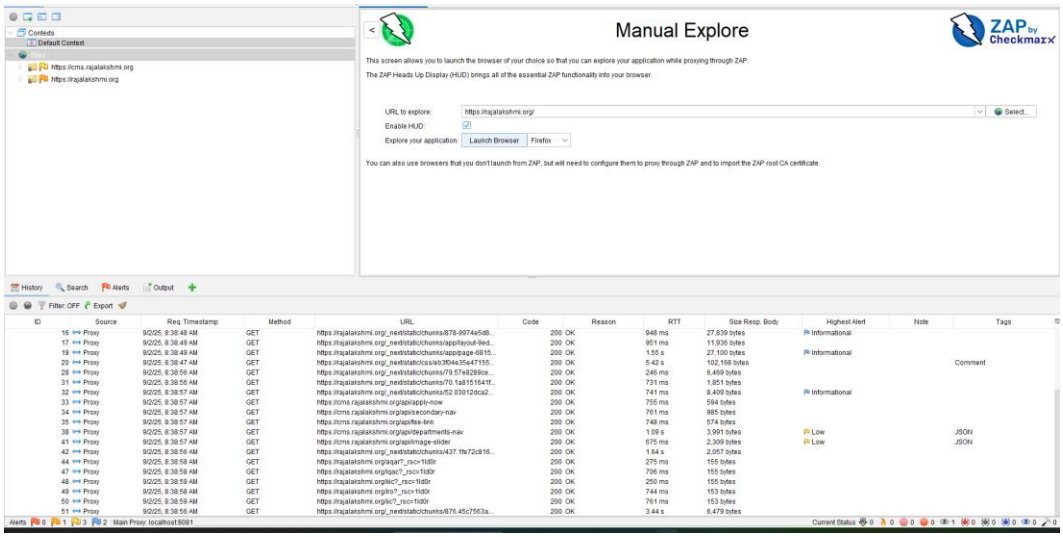
Result: Dynamic Application Security Testing (DAST) reveals various vulnerabilities.

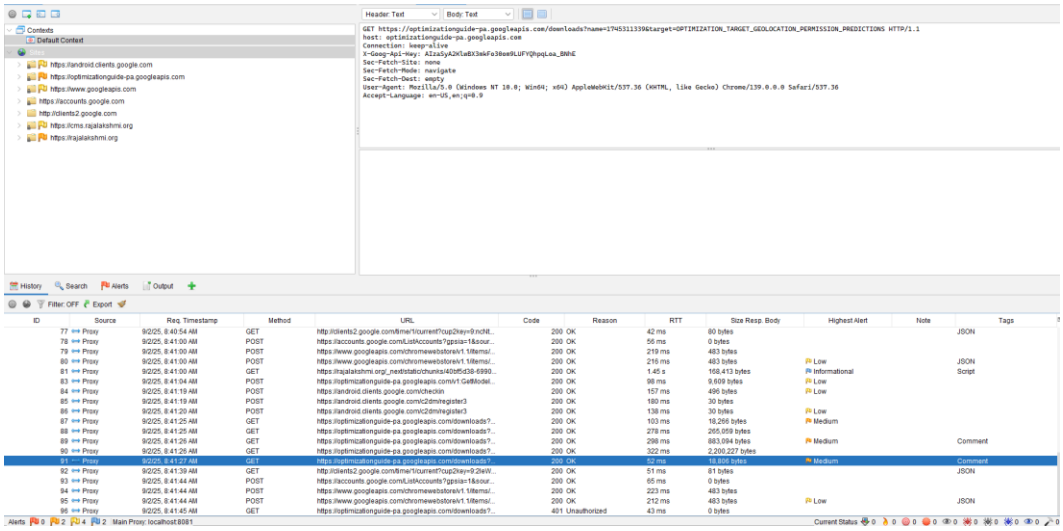
Screenshots

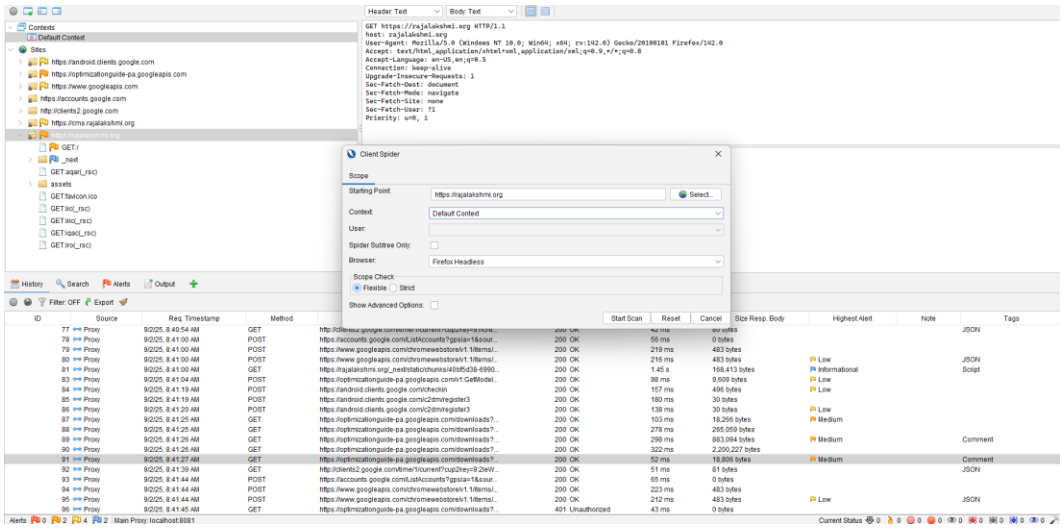


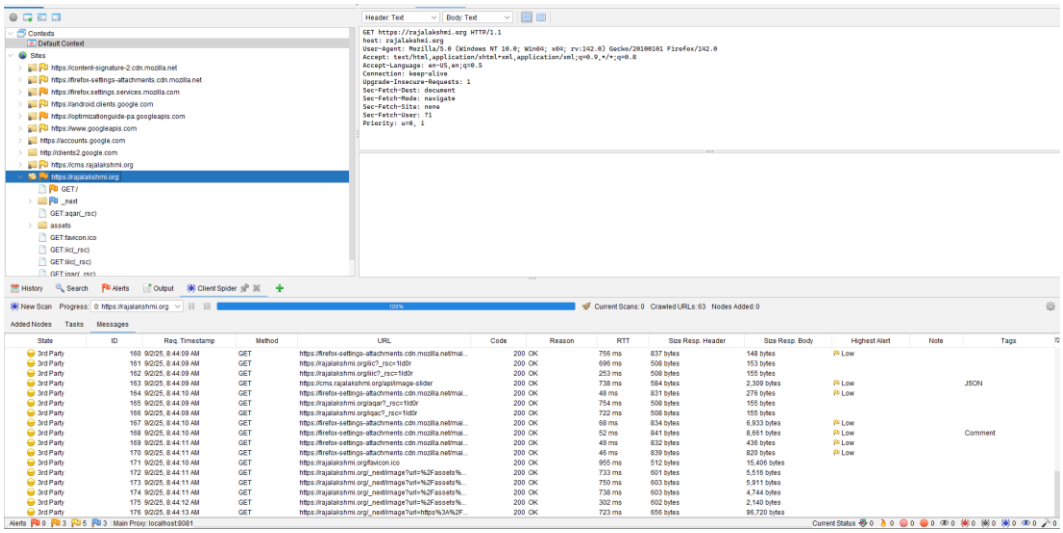


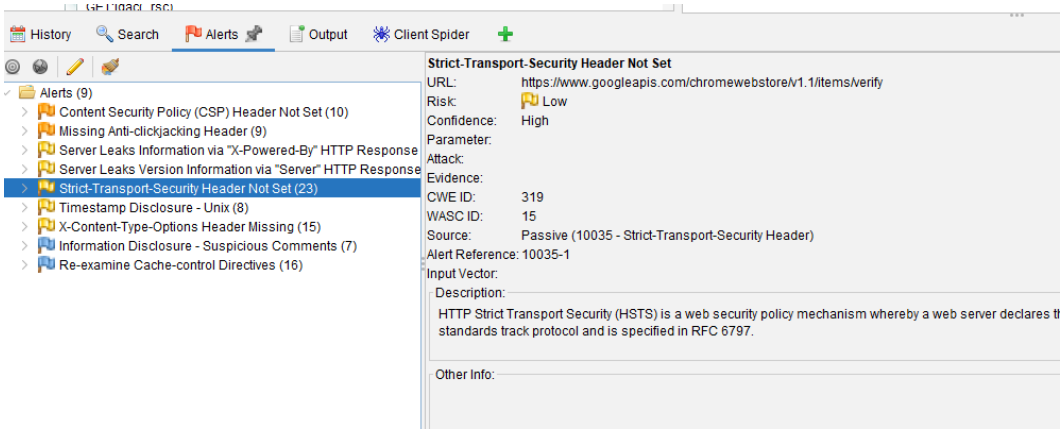

Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
https://rajalakshmi.org/
Select...
Enable HUD:
Explore your application:
Launch Browser
Firefox
You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.


Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
https://rajalakshmi.org/
Select...
Enable HUD:
Explore your application:
Launch Browser
Firefox
You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.


GET https://optimizationguide-pa.googleapis.com/downloads?name=1745311339&target=OPTIMIZATION_TARGET_GEOLOCATION_PERMISSION_PREDICTIONS HTTP/1.1
host: optimizationguide-pa.googleapis.com
Connection: keep-alive
X-Goog-Api-Key: AIzaSyA2KlwBX3mkFo30om9LUFYQhpqLoa_BNhE
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: empty
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
Accept-Language: en-US,en;q=0.9






History
Search
Alerts
Output
Client Spider
Alerts (9)
Content Security Policy (CSP) Header Not Set (10)
Missing Anti-clickjacking Header (9)
Server Leaks Information via "X-Powered-By" HTTP Response
Server Leaks Version Information via "Server" HTTP Response
Strict-Transport-Security Header Not Set (23)
Timestamp Disclosure - Unix (8)
X-Content-Type-Options Header Missing (15)
Information Disclosure - Suspicious Comments (7)
Re-examine Cache-control Directives (16)
Strict-Transport-Security Header Not Set
URL: https://www.googleapis.com/chromewebstore/v1.1/items/verify
Risk: Low
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 319
WASC ID: 15
Source: Passive (10035 - Strict-Transport-Security Header)
Alert Reference: 10035-1
Input Vector:
Description:
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares th
standards track protocol and is specified in RFC 6797.
Other Info: